

Stoquify Internal Activation Gate Blocker Closure and Next-Stage Execution Report

Final local revision: 2026-07-25

Prompt executed: STOQUIFY_INTERNAL_ACTIVATION_GATE_BLOCKER_CLOSURE_AND_NEXT_STAGE_EXECUTION_PROMPT_2026-07-24

Scope: Agent Runtime Phase 2 controlled-pilot trust gates

Local repository result: Material repository blockers closed and verified

Release decision: NO-GO - READY FOR CONTROLLED REMEDIATION VERIFICATION

Internal activation: Blocked and not attempted

Phase 3: Not authorized

Guardrail result: 016-aqstoqflow-ai-copilot-guardrails passed for the implemented Phase 2A boundary

Independent release result: 017-aqstoqflow-enterprise-release-gate rerun; NO-GO for activation while external gates remain open

1. Executive Decision

The blocker-closure prompt was executed against Stoquify's current code, local PostgreSQL database, Prisma migrations, release-control services, protected actions, browser harness, and generated evidence.

The repository is now materially stronger. It has:

- A shared, Stoquify-native, read-only Command Agent path.
- Release authorization before runtime execution.
- Tenant, RBAC, module, manifest, approval, ownership, certification, reconciliation, and alert-health controls.
- Guarded suspension and retirement with audit evidence.
- Retry-safe webhook delivery with terminal DEAD_LETTER.
- An authorized, tenant-scoped, idempotent, audited dead-letter recovery operation.
- Protected-business-data fingerprinting before and after browser certification.
- Exact allowed-persistence accounting for agent runs, steps, evidence links, feedback, costs, and policy incidents.
- Desktop and mobile enabled-pilot certification, denied-role and second-tenant release-isolation certification, automated accessibility scanning, feedback persistence, replay proof, and overflow checks.
- Separate desktop and mobile kill-switch certification.
- A provider-neutral five-minute scheduler worker with bounded retry and timeout policy.
- A durable PostgreSQL invocation ledger with replay, overlap, stale-lease, cadence, heartbeat, and sanitized failure controls.
- A dual-version reconciler credential path for controlled rotation without permanent fallback.
- A value-free, machine-validatable credential-rotation register that fails closed until real security evidence is recorded.
- A unified operational release evidence gate that binds CI, artifact, approvals, owners, scheduler, alerting, and credential rotation without granting activation authority.
- A provider-neutral reconciler evidence collector that proves invalid authentication, sanitizes three real windows, hash-binds readiness, and patches scheduler evidence only.

- A provider-neutral alert evidence collector that proves invalid authentication, sanitizes and hash-binds live alert operations, validates owner/SLO alignment, and patches alerting evidence only.
- A provider-neutral governance evidence collector that rejects local E2E identities, binds real approvals and six-owner coverage to the frozen release, and patches governance fields only.
- A provider-neutral CI/release evidence collector that binds clean CI, certified package proof, artifact, deployment, browser report, and allowlists into one immutable release identity.
- A provider-neutral credential evidence collector that requires all 15 classes exactly once, rejects value-bearing evidence, binds a fresh security attestation to that frozen inactive release, and patches only the credential register and its operational hash/reference.

The final local package is `PILOT_CERTIFIED`, but it is not activated. `activatedAt` remains null.

Stoquify is not yet authorized for a real internal pilot because the remaining gates require real people, real infrastructure, an immutable clean commit, and production-like operational evidence. Test identities and local PostgreSQL records do not substitute for those decisions.

2. Final Package and Certificate

Field	Verified value
Organization	<code>org_payroll_e2e_local</code>
Package ID	<code>cmrzwa2ya0003ma80pkepes3p</code>
Package state	<code>PILOT_CERTIFIED</code>
Activated	No
Activation timestamp	null
Release version	<code>e2e-ac30ee75314a-1784955267417</code>
Recorded Git SHA	<code>ac30ee75314a0a2a2fcd6bd2ed65afb280aad5e</code>
Manifest hash	<code>sha256:f6d5f1049e0baff64bb42503077f3fe801bd214bcf265289308f7db56f51c28a</code>
Certification ID	<code>cmrzwf8p20001maokeh17y448</code>
Certification result	<code>PASSED</code>
Certification expiry	<code>2026-07-26T04:58:28.099Z</code>
Sanitized report SHA-256	<code>92c3c05e239615c963192176953f21f6e0d766879913788e22c5b710ffc82847</code>

The recorded SHA is the local HEAD used by the harness. It is not a final release identity because the worktree contains uncommitted changes and no clean-commit CI certificate exists.

3. Repository Blockers Closed

3.1 Protected dead-letter recovery

Implemented:

- `services/assurance/assurance-alert-recovery.service.ts`
- `actions/assurance/workflow-assurance-alert.actions.ts`
- Focused service and protected-action tests
- Static release-gate checks
- PostgreSQL recovery smoke coverage

The operation:

- Accepts only tenant-scoped webhook deliveries already in `DEAD_LETTER`.
- Requires an active tenant operator and protected `controls.manage` action.
- Requires bounded reason and idempotency key.
- Leaves the source dead-letter immutable.
- Creates one new `PENDING` successor at attempt zero.
- Replays the same successor for the same idempotent request.
- Rejects conflicting reuse of the key.
- Writes Workflow Assurance and `AuditLog` evidence.

Direct database recovery remains prohibited.

3.2 Allowed-persistence certification

The browser certifier now counts tenant-scoped rows before and after the run.

Persistence class	Before	After	Delta	Decision
Agent runs	36	38	2	Expected
Agent steps	72	76	4	Expected
Evidence links	360	380	20	Expected
Feedback	24	26	2	Expected
Cost ledger	0	0	0	Required
Policy incidents	0	0	0	Required

The certifier rejects duplicate executions, unexpected feedback, cost writes, or policy incidents.

3.3 Browser trust certification

The final enabled-pilot report records:

- 14 expected tests
- 14 passed
- 0 unexpected
- 0 skipped
- 0 flaky
- Desktop and mobile baseline projects completed before the serialized degradation project
- DRAFT governance denial with no agent-run persistence
- Release-role scope denial with a non-disclosing `Forbidden` response and no agent-run persistence
- Release-manifest mismatch denial with no agent-run persistence

- Expired required approval denial with no agent-run persistence
- Expired required owner coverage denial with no agent-run persistence
- Second-tenant denial with zero governed release packages, a disabled Generate control, and no agent-run persistence
- Suspended-release rollback denial with no agent-run persistence
- Auth setup for the allowed, denied-role, and second-tenant fixtures
- Desktop and mobile governed Command Agent execution
- Desktop and mobile denied-role behavior
- Keyboard launch after full hydration
- Read-only authority disclosure
- Evidence-backed output or explicit permitted empty state
- Tenant-internal evidence-link validation
- Automated serious/critical axe checks
- One bounded feedback record per viewport
- Idempotent Retry returning the existing receipt
- No horizontal viewport overflow

Raw Playwright JSON is not retained. The sanitized report contains no environment block and no forbidden credential-bearing key.

3.4 Protected-business-data immutability

Fingerprint version: `agent-protected-business-data-v1`

Before:

```
sha256:8990cc283e026dd997527ecb211ff348793683a7e7a99f03e2b63ab0c88bfe5e
```

After:

```
sha256:8990cc283e026dd997527ecb211ff348793683a7e7a99f03e2b63ab0c88bfe5e
```

Result: unchanged.

The fingerprint uses ordered tenant-safe projections across accounting, compliance, payments, stock and inventory, purchasing, payroll, roles, and user-role membership. It does not expose raw personal or secret data in browser evidence.

3.5 Authentication and timing hardening

The enabled-pilot wrapper now binds:

- `PLAYWRIGHT_BASE_URL`
- `NEXTAUTH_URL`
- `NEXT_PUBLIC_BASE_URL`

to the same isolated certification origin. This prevents Better Auth cookies from being issued for the `.env` development origin while Playwright runs on another port.

Interactive certification waits for hydration-safe `networkidle` navigation. Tests use a bounded six-minute budget because a cold Next.js development navigation consumed approximately two minutes in trace evidence. Denied read-only navigation remains on `domcontentloaded`.

3.6 Kill-switch proof

The complementary kill-switch run passed:

- 2 auth setup cases
- Desktop fail-closed Command Agent surface
- Mobile fail-closed Command Agent surface
- 4/4 total

The first invocation was blocked by occupied port `3000`; no test ran. The successful rerun used isolated port `3108` with Better Auth bound to the same origin.

3.7 Five-minute reconciler control plane

Implemented and locally verified:

- Provider-neutral worker command: `npm run agent:reconciler:invoke`.
- Authenticated `POST /api/internal/agents/reconcile-abandoned` invocation with deterministic five-minute run identity.
- Authenticated `GET /api/internal/agents/reconcile-abandoned` readiness contract.
- Additive `agent_reconciler_invocations` ledger migration.
- Serializable acquisition and one active lease per environment.
- Completed replay without re-execution and conflicting replay rejection.
- Stale-lease terminalization before a later window acquires the lease.
- Three-window cadence, heartbeat, alert-health, and stale-lease readiness blockers.
- Bounded timeout and retry using the same durable run identity.
- Current and previous secret slots for a controlled two-version rotation window.
- Sanitized `401`, `409`, `500`, and `503` responses with correlation identifiers.

The deployment contract is `docs/agents-runtime/STOQUIFY_AGENT_RECONCILER_DEPLOYMENT_CONTRACT_2026-07-24.md`. This closes the repository implementation gap only. No production-like schedule, managed secret, alert transport, or real scheduler window was created.

3.8 Credential-rotation completion register

Implemented:

- Machine source: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_CREDENTIAL_ROTATION_REGISTER_2026-07-25.json`
- Human register: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_CREDENTIAL_ROTATION_REGISTER_2026-07-25.md`
- PDF register: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_CREDENTIAL_ROTATION_REGISTER_2026-07-25.pdf`
- Report command: `npm run agent:credential-rotation:report`
- Fail-closed command: `npm run agent:credential-rotation:gate`

The register covers 15 credential classes and retains no credential value, token, password, authorization header, database URL, or environment snapshot. Structural tests prove complete rotation/revocation evidence, test-only classification evidence, timestamp order, and forbidden-value rejection.

Its current status is correctly `BLOCKED`: 15 classifications are unresolved, the real security owner and approval are absent, authority provenance is absent, and the register is not bound to a frozen deployment. The fail-closed command exits nonzero with 31 blockers. This is not an implementation failure; it is enforceable evidence that

real classification, rotation, revocation, workload restart, new-version verification, old-version rejection, fresh attestation, and release binding have not been supplied.

3.9 Operational release evidence gate

Implemented:

- Machine source: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_OPERATIONAL_RELEASE_EVIDENCE_2026-07-25.json`
- Human report: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_OPERATIONAL_RELEASE_EVIDENCE_2026-07-25.md`
- Fail-closed commands: `npm run agent:operational-release:report` and `npm run agent:operational-release:gate`
- Required release ordering in `verify:release`
- Phase 2A static-ratchet coverage and 21 focused operational-gate tests

The gate binds the inactive certified package, clean CI identity, immutable artifact, current and distinct product/security approvals, all six real owner responsibilities, three five-minute scheduler windows, fresh heartbeat and readiness, negative authentication/configuration evidence, alert delivery/acknowledgement/escalation/recovery, and the independently evaluated credential-rotation register.

Its current result is correctly `BLOCKED` with 146 precise missing-evidence items. It rejects synthetic identities, raw values masquerading as references, forbidden secret-bearing fields, stale windows, unbound or drifting hashes, scheduler cadence drift, acknowledgement outside SLO, blocked credential rotation, and any activation field. Even a complete register can become only `READY_FOR_INDEPENDENT_REVIEW`; `activationAuthorized` is always false.

3.10 Reconciler readiness evidence capture

Implemented:

- `scripts/agent-reconciler-evidence-capture.js`
- `scripts/__tests__/agent-reconciler-evidence-capture.test.js`
- Sanitized readiness windows in `services/agents/agent-reconciler-invocation.service.ts`
- Report, fail, and guarded-apply package commands
- `docs/agents-runtime/STOQUIFY_AGENT_RECONCILER_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The collector performs an ephemeral invalid-auth probe and an authenticated readiness probe, requires an exact environment match, accepts only known readiness fields and blocker codes, caps the response at 100 KB, computes a SHA-256 over the sanitized capture, and emits no secret, authorization header, raw response, database target, tenant data, or business payload.

A ready capture can update only scheduler readiness, evidence hash/reference, heartbeat, invalid-auth reference, and the three captured windows. It refuses blocked captures, environment mismatch, or any register whose activation fields are not false/false/null. Eight collector tests and the expanded readiness tests passed. The real collector preflight remains correctly blocked on `RECONCILER_BASE_URL_MISSING`; no external evidence was fabricated.

3.11 Alert operational evidence capture

Implemented:

- `scripts/agent-alert-evidence-capture.js`
- `scripts/__tests__/agent-alert-evidence-capture.test.js`

- Report, fail, and guarded-apply package commands
- Hash-bound `alerting.evidenceSha256` release requirement
- `docs/agents-runtime/STOQUIFY_AGENT_ALERT_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The collector performs an ephemeral invalid-auth probe and an authenticated query-free HTTPS evidence probe. It accepts only the alert delivery, acknowledgement, retry, dead-letter, recovery, escalation, rotation, environment, owner, and SLO fields needed for independent review; unknown and unsafe fields are discarded before hashing.

A ready capture can update only the alerting section. It requires evidence no older than 24 hours, acknowledgement within SLO, a real security incident owner, a real on-call escalation owner, an exact environment match, and activation false/false/null. Nine collector tests passed. The real preflight remains correctly blocked on `ALERT_EVIDENCE_URL_MISSING`; no external evidence was fabricated.

3.12 Governance operational evidence capture

Implemented:

- `scripts/agent-governance-evidence-capture.js`
- `scripts/__tests__/agent-governance-evidence-capture.test.js`
- Report, fail, and guarded-apply package commands
- Hash-bound and 24-hour-fresh `governance` release requirement
- `docs/agents-runtime/STOQUIFY_AGENT_GOVERNANCE_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The collector performs an ephemeral invalid-auth probe and an authenticated query-free HTTPS authority probe. It accepts only a release-bound attestation, distinct product/security approvals, and the six required owner records. Synthetic identities and unknown fields are rejected or discarded before hashing.

A ready capture can update only governance, approvals, and owners. It refuses local Prisma identities, release drift, expired approvals, incomplete or expired coverage, environment mismatch, a package outside inactive `PILOT_CERTIFIED`, or activation other than false/false/null. Nine collector tests passed. The real preflight remains correctly blocked on `GOVERNANCE_EVIDENCE_URL_MISSING`; no identity or approval was fabricated.

3.13 CI and release operational evidence capture

Implemented:

- `scripts/agent-ci-release-evidence-capture.js`
- `scripts/__tests__/agent-ci-release-evidence-capture.test.js`
- Report, fail, and guarded-apply package commands
- Certified-package proof, shared CI/release capture hash, and 24-hour freshness requirements
- `docs/agents-runtime/STOQUIFY_AGENT_CI_RELEASE_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The collector performs an ephemeral invalid-auth probe and an authenticated query-free HTTPS attestation probe. It requires clean and passed CI, fresh completion and attestation, inactive `PILOT_CERTIFIED` proof, and exact commit/artifact/browser alignment across release and CI.

A ready capture can update only release and CI. It refuses dirty or stale builds, activation, package-certification gaps, source/release hash drift, environment mismatch, and conflicts with any nonempty identity already in the register. Nine collector tests passed. The real preflight remains correctly blocked on `CI_RELEASE_EVIDENCE_URL_MISSING`; no CI or release evidence was fabricated.

3.14 Credential rotation operational evidence capture

Implemented:

- `scripts/agent-credential-rotation-evidence-capture.js`
- `scripts/__tests__/agent-credential-rotation-evidence-capture.test.js`
- Report, fail, and guarded two-register apply commands
- Fresh authority, invalid-auth, exact class-set, frozen-release, and immutable completed-evidence requirements
- `docs/agents-runtime/STOQUIFY_AGENT_CREDENTIAL_ROTATION_EVIDENCE_CAPTURE_RUNBOOK_2026-07-25.md`

The collector performs an ephemeral invalid-auth probe and an authenticated query-free HTTPS security-authority probe. It rejects value-bearing fields, synthetic identities, stale attestations, missing/extra/duplicate credential classes, owner or approval drift, timestamp disorder, and release identity mismatch.

A ready capture can update only the value-free credential register and the operational credential-rotation hash/reference binding. It cannot rotate a credential itself, change another operational evidence section, alter status, or authorize activation. Nine collector tests and eight credential-gate tests passed. The real preflight remains correctly blocked on `CREDENTIAL_EVIDENCE_URL_MISSING`; no credential event, identity, approval, or evidence artifact was fabricated.

4. PostgreSQL Release-Control Evidence

The final PostgreSQL smoke passed with:

- Package state: `PILOT_CERTIFIED`
- `activatedAt`: null
- Approval records: 2 E2E records from distinct identities
- Owner records: 6 E2E records
- Certification records: 1
- Audit records: 18
- Approval replay: idempotent
- Certification replay: idempotent
- Conflicting replay: `RELEASE_IDEMPOTENCY_CONFLICT`
- Automatic suspension: persisted and audited
- Tenant suspension did not deactivate the global definition
- Retirement after suspension: persisted and audited
- Dead-letter state: `DEAD_LETTER`
- Dead-letter attempt count: 5
- Recovery successor: `PENDING`, attempt count 0
- Recovery replay: same successor returned
- Recovery audit: present

The local reconciler scanned 16 release packages: 15 passed and 1 failed. Local alert transport remains unavailable because the webhook URL is missing. The activation attempt remained blocked by `RELEASE_RECONCILIATION_STALE`.

The automatic-suspension fixture intentionally entered `SUSPENDED` and then `RETIRED`. It is separate from the final certified package.

The scheduler-ledger PostgreSQL smoke also passed:

- Invocation rows: 3 isolated smoke records
- Concurrent overlap: rejected
- Completed replay: returned without duplicate execution
- Conflicting replay: rejected
- Expired lease: terminalized and recovered
- Terminal failure: retained with stable failure code
- Active leases after completion: 0
- Smoke rows after cleanup: 0

5. Final Verification Register

Verification	Result
Focused error-boundary Jest	24 suites, 99 tests passed
Complete Jest	473 suites passed, 3 skipped; 2,852 tests passed, 15 skipped; intermittent forced-worker-exit warning observed after completion
Scheduler-focused Jest	5 suites, 33 tests passed
Credential-rotation gate Jest	1 suite, 8 tests passed
All focused operational-evidence Jest	7 suites, 73 tests passed; <code>--detectOpenHandles</code> clean
Full TypeScript check	Passed
Production build	Passed across the complete route tree with an explicit 8 GB Node heap; three existing image warnings
Focused ESLint	Passed
Prisma schema validation	Passed
Migration safety gate	Ready; 8/8 checks
Prisma migrations	34; database up to date
Migration risk findings	0
Agent tool-registry gate	Passed
Agent prohibited-action gate	Passed
Agent release-control gate	Passed
PostgreSQL release-control smoke	Passed
PostgreSQL scheduler-ledger smoke	Passed: overlap, replay, conflict, stale lease, terminal failure, and cleanup
Enabled-pilot Playwright	14/14 passed; desktop/mobile baseline plus DRAFT, scope, manifest, approval-expiry, owner-expiry, second-tenant, and suspension degradation scenarios
Kill-switch Playwright	4/4 passed

Verification	Result
Protected-data fingerprint	Passed
Allowed-persistence policy	Passed
Raw report absence	Passed
Sanitized evidence forbidden-key scan	Passed
<code>git diff --check</code>	Passed; line-ending notices only
Full clean-commit CI	Not run
Full <code>verify:repo</code>	Attempted; stopped only at statutory country-pack evidence, 10/12 checks ready
Production-like scheduler	Not deployed
Production-like alert delivery and acknowledgement	Not run
Credential-rotation register	Generated and value-free; 15 classes, 31 blockers
Real credential rotation	Not evidenced; fail-closed gate exits nonzero
Skill 017 enterprise release gate	Rerun; <code>NO-GO</code> for activation because external/human/deployment evidence is absent

6. Intermediate Failures and Corrections

No failed browser run issued a certificate.

Failure	Cause	Correction
Feedback assertion expired	Server action exceeded Playwright's default five-second assertion window	Added a bounded 30-second persistence wait
Denied-role panel was absent	Existing Daily Digest RBAC denied the entire workspace before the agent component	Certified route-level denial, no panel, no Generate control, and accessibility
Permission snapshots were empty	Better Auth origin differed from Playwright origin	Bound all auth and browser base URLs to one isolated origin
Local users became locked	Rejected sign-in attempts accumulated during origin failure	Used the sanctioned payroll E2E seed/reset before baseline capture
Positive tests timed out after completing assertions	Cold development navigation consumed most of the 180-second test budget	Used a trace-supported six-minute bounded budget
<code>domcontentloaded</code> did not start generation	SSR control was visible before React hydration	Restored <code>networkidle</code> for the interactive positive path
Kill-switch server failed to start	Port <code>3000</code> was occupied	Reran on isolated port <code>3108</code>
First clean build rerun failed	Local Node process exhausted array-buffer memory and invalidated partial <code>.next</code> output	Reran the safe build wrapper with an explicit 8 GB heap; wrapper cleaned only generated stale output and returned a valid build with exit code 0

Failure	Cause	Correction
Second tenant had no visible digest workspace	Its read-only role lacked every digest-specific permission	Added only <code>accounting.close.read</code> so the fixture could reach the core Daily Digest while retaining zero release packages
Second-tenant scenario timed out on Generate	Release authorization had already failed closed and disabled the control	Asserted zero release packages, the disabled safe state, and unchanged tenant run count directly

These are harness and environment corrections. None grant the agent additional authority.

7. Current Gate Classification

Gate	Current status	Classification
Shared runtime and Command Agent authority boundaries	Passed locally	Repository
Tenant/RBAC/module/release authorization	Passed locally	Repository
Dead-letter recovery	Passed locally	Repository
Protected-data non-mutation	Passed locally	Repository
Exact allowed-persistence accounting	Passed locally	Repository
Enabled desktop/mobile pilot UI	Passed locally	Repository
Denied role and automated accessibility	Passed locally	Repository
Kill switch	Passed locally	Repository
High-risk browser degradation matrix	Expanded and locally certified for DRAFT, scope, manifest mismatch, expired approval, expired owner coverage, second-tenant, and suspension denial	Repository
Provider-neutral scheduler worker and invocation ledger	Passed locally	Repository/database
Scheduler overlap, replay, stale lease, cadence, readiness, and dual-secret code paths	Passed locally	Repository/database
Clean immutable commit and CI artifact	Blocked	Repository/process
Potential non-test credential rotation	Blocked	Security authority
Real product and security approvals	Blocked	Human authority
Real six-responsibility owner roster	Blocked	Human authority
Deployed five-minute reconciler	Blocked	Deployment
Production-like alert delivery, acknowledgement, and escalation	Blocked	Deployment/external

Gate	Current status	Classification
Final independent enterprise release decision	Blocked by dependencies	Governance

8. Browser and Degradation Evidence Status

The dependency-ordered browser certificate now closes seven high-value user-surface gaps:

1. A DRAFT definition is denied before run persistence.
2. A release-role mismatch is denied with the non-disclosing `Forbidden` response before run persistence.
3. A release-manifest mismatch is denied before run persistence.
4. An expired required approval is denied before run persistence.
5. Expired required owner coverage is denied before run persistence.
6. A second tenant with zero governed release packages sees a disabled safe state and persists no agent run.
7. A suspended package produces a safe rollback state before run persistence.

The certificate issuer now refuses skipped, flaky, unexpected, incomplete, raw, or environment-bearing reports. The local sanitized report records 14/14 passing tests, the required desktop/mobile baseline, all seven degradation scenarios, unchanged protected business data, exactly two intended baseline runs and feedback records, and zero costs or policy incidents.

Existing service, action, component, and PostgreSQL evidence covers concurrent duplicate recovery, stale reconciliation and unhealthy alert transport, explicit non-empty evidence, partial/stale/unavailable source states, redactions, cross-tenant feedback rejection, and guarded suspension.

The previously proposed "unentitled dashboard tenant" browser fixture is not valid for this Command Agent architecture. `dashboard` is a core catalog module and is deliberately derived as `system_default`; `dashboard.read` and release authorization are the operative controls. A focused entitlement test now locks that contract, while the denied-role browser path proves the RBAC boundary. Any future agent attached to a non-core module must add its own unentitled-module browser case.

The remaining environment-dependent evidence for a clean immutable release is narrower:

1. Stale reconciliation and unhealthy transport denial in a production-like internal environment. The guarded E2E certification session intentionally bypasses those operational checks and must never create an `ACTIVE_INTERNAL` package to simulate them.
2. Production-like user-surface rollback after the deployed reconciler performs guarded suspension.

These scenarios require controlled environment or identity fixtures. They do not justify weakening the E2E `PROVISIONED_INACTIVE` boundary.

9. How to Close Every Remaining Gate

9.1 Credential response

The security owner must:

1. Inventory every potentially exposed non-test credential without printing its value.
2. Map each credential to its managed secret reference and dependent workload.
3. Create a new version.

4. Redeploy dependants with the new version.
5. Verify new-version success.
6. Revoke the old version.
7. Verify old-version rejection.
8. Invalidate related sessions or tokens where applicable.
9. Record owner, timestamps, references, environment, and results.
10. Bind the rotation register to the security approval.

Deleting a local report is not rotation evidence.

The completion artifact is `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_CREDENTIAL_ROTATION_REGISTER_2026-07-25.json`, with matching Markdown and PDF renderings. A security owner must update the machine source with value-free references and timestamps, regenerate the report, and obtain a passing `npm run agent:credential-rotation:gate` result.

9.2 Clean commit and CI

The engineering and release owners must:

1. Review the dirty worktree and separate unrelated user changes.
2. Confirm that raw reports, auth states, traces, secrets, database URLs, and local-only artifacts are excluded.
3. Run the full repository verification command.
4. Create an authorized commit.
5. Push to a controlled branch.
6. Run CI from the exact commit.
7. Retain the sanitized browser report, state, report hash, CI run ID, and immutable artifact URL.
8. Build and deploy the exact certified artifact or image digest.
9. Create a new release package bound to that exact SHA, manifest, and artifact.
10. Invalidate the certificate if source, manifest, migrations, prompt, tool, or skill versions change.

9.3 Real approvals

Product and security decisions must be recorded by distinct, real, authorized identities:

1. Freeze the exact package manifest and evidence hash.
2. Product approver uses fresh authentication and product approval permission.
3. Security approver independently reviews threat, credential, and control evidence.
4. Each decision records rationale, residual risks, expiry, and audit event.
5. Rejection, revocation, expiry, or manifest drift invalidates readiness.

E2E approvers cannot be promoted into production evidence.

9.4 Owner roster

Assign real primary and backup coverage for:

- Rollout
- Rollback
- Support
- Pilot

- Security incident
- On-call backup

Each record needs a real directory identity, accepted runbook version, coverage window, validity, and escalation route.

9.5 Five-minute reconciliation

The repository implementation is complete and documented in `docs/agents-runtime/STOQUIFY_AGENT_RECONCILER_DEPLOYMENT_CONTRACT_2026-07-24.md`. Deploy the worker command:

```
npm run agent:reconciler:invoke
```

which invokes:

```
POST /api/internal/agents/reconcile-abandoned
```

with managed authentication.

Required proof:

1. Exact deployed commit and artifact digest.
2. Managed secret or reviewed workload identity.
3. Five-minute schedule.
4. Single-concurrency or lease-safe execution.
5. Timeout below the schedule interval.
6. Three consecutive successful windows.
7. Heartbeat freshness.
8. Verified `401` for invalid auth and `503` for missing server configuration.
9. Rotation proof for the reconciler credential.
10. Alerts for schedule failure or stale heartbeat.

9.6 Alert transport and escalation

Configure managed:

- `STOQUIFY_ASSURANCE_ALERT_WEBHOOK_URL`
- `STOQUIFY_ASSURANCE_ALERT_WEBHOOK_SECRET`

Then prove:

1. HTTPS delivery.
2. External request reference.
3. Named owner acknowledgement within SLO.
4. Transient retry with bounded jitter.
5. Five failures reaching `DEAD_LETTER`.
6. Duplicate queueing preserving terminal state.
7. Protected recovery producing one audited successor.
8. Acknowledgement expiry escalating to the backup owner.
9. Secret rotation and old-secret rejection.

9.7 Final independent release gate

Only after all preceding evidence exists:

1. Freeze the evidence bundle.
2. Run `017-aqstoqflow-enterprise-release-gate`.
3. Issue `GO`, `CONDITIONAL GO`, or `NO-GO`.
4. Keep activation as a separate protected ceremony.
5. Record the actor, package, manifest, artifact, scope, window, and rollback owner.

10. Activation Ceremony

Even after a `GO`, activation must remain separate:

1. Revalidate certificate freshness.
2. Revalidate approvals and owner coverage.
3. Revalidate scheduler heartbeat and alert health.
4. Revalidate pilot tenant and role allowlists.
5. Record the activation decision with fresh authentication.
6. Activate only the approved internal scope.
7. Observe run, alert, and feedback telemetry.
8. Suspend immediately on blocking drift.
9. Prove rollback denial and protected-data integrity.

The agent must never activate itself.

11. Next-Stage Roadmap

Stage A: Finish repository evidence

- Preserve the expanded 11-test certificate and its fail-closed report contract.
- Run full repository verification.
- Review and commit the intended change set.
- Obtain clean-commit CI evidence.

Exit: immutable repository evidence exists.

Stage B: Close security and operations

- Rotate potentially exposed credentials.
- Deploy the five-minute reconciler.
- Configure and prove alert delivery, acknowledgement, escalation, and recovery.
- Assign and record the real owner roster.

Exit: operational controls are live and evidenced.

Stage C: Record governance decisions

- Product approval.
- Independent security approval.

- Owner acceptance.
- Evidence freeze.

Exit: all human gates are current and bound to the exact package.

Stage D: Run skill 017

- Execute the independent enterprise release gate.
- Resolve every condition or retain NO-GO.

Exit: an authorized release decision exists.

Stage E: Controlled internal pilot

- Perform a separate activation ceremony.
- Use a narrow tenant and role allowlist.
- Monitor continuously.
- Preserve immediate guarded suspension.

Phase 3 is authorized only after the controlled pilot meets its exit metrics and produces no unresolved high-severity incident.

12. Permanent Authority Boundary

No agent, skill, model, worker, or browser harness may receive:

- Direct Prisma writes to business truth
- Ledger posting authority
- Payment initiation or execution authority
- Statutory filing authority
- Payroll calculation, approval, salary, destination, or payment authority
- Stock adjustment, transfer, write-off, or valuation authority
- Close certification or evidence mutation authority
- Role, permission, entitlement, or membership authority
- Product approval, security approval, or self-activation authority

All business changes remain behind Stoquify-owned protected actions, domain services, fresh authentication, RBAC, maker-checker controls, audit, and Workflow Assurance.

13. Final Repository Verification and Independent Gate Rerun

The final repository-controlled verification pass produced the following additional evidence:

Gate or verification	Result
Raw error-boundary fail gate	Passed; 0 active unsafe findings, 88 reviewed safe classifications
Command action non-leakage regression	Passed; unexpected runtime details map to non-exposing INTERNAL_ERROR
Focused runtime regression bundle	24 suites, 99 tests passed

Gate or verification	Result
Complete Jest run	473 suites passed, 3 skipped; 2,852 tests passed, 15 skipped; intermittent forced-worker-exit warning observed after completion
Full TypeScript check	Passed
Production build	Passed
Agent runtime gates	Passed: read-only registry, prohibited-action boundary, release-control safeguards
Phase 2A static gate	Passed; narrow, read-only, provider-free, with dependency-ordered degradation certification enforced
Enabled-pilot browser certificate	14/14 passed; zero skips, flakes, and unexpected results
Browser degradation persistence	DRAFT, role-scope, manifest-mismatch, expired-approval, expired-owner, second-tenant, and suspension denials each persisted zero agent runs
Cross-tenant browser isolation	Second organization had zero release packages, a disabled Generate control, and zero agent-run persistence
Consolidated Phase 2A regression	23 suites and 85 tests passed
Phase 2A PostgreSQL smoke	Passed: feedback uniqueness, cross-tenant rejection, provenance round trip
Release-control PostgreSQL smoke	Passed: replay, conflict, drift suspension, retirement, dead-letter and recovery evidence
Reconciler-ledger PostgreSQL smoke	Passed: overlap rejection, completed replay, conflicting replay rejection, stale-lease recovery, terminal failure, and zero active leases
Credential-rotation register	15 credential classes; value-free report generated; release gate blocked on 17 genuine security-evidence gaps
Operational release evidence	Value-free register generated; fail-closed on 146 real deployment/governance evidence gaps; activation authority always false
CI release readiness	Ready, 11/11 checks
Prisma migration safety	Ready, 8/8 checks; 34 migrations; zero destructive findings
Release secret preflight	Conditional locally; six production-secret warnings, enforcement off
Release evidence synthesis	Conditional; 10/11 structural checks and three release-only blockers
Statutory country-pack production gate	Blocked, 10/12; source artifact hash and expert approval are absent

The release-control smoke remained fail-closed: the final package was `PILOT_CERTIFIED`, never activated, alert transport was unavailable because no managed webhook was configured, and activation was rejected for stale reconciliation. Synthetic smoke identities and E2E ownership records are test evidence only.

Scheduler control-plane completion

The final repository slice adds the operational mechanism that the earlier report could only prescribe:

- `services/agents/agent-reconciler-invocation.service.ts`
- `scripts/run-agent-reconciler-schedule.js`
- `scripts/agent-reconciler-postgres-smoke.ts`
- `prisma/migrations/20260724193000_agent_reconciler_invocation_ledger/migration.sql`
- Authenticated readiness and execution behavior in the reconciler route
- Rotation-safe current/previous credential verification
- Static, unit, route, error-boundary, migration, build, and real PostgreSQL evidence

This mechanism is locally complete but operationally inactive. It has not been bound to a deployment provider, managed schedule, production-like secret store, healthy alert endpoint, or named operations owner. Three real consecutive five-minute windows and real credential revocation therefore remain unproven.

Independent skill decisions

Detailed ordered rerun: `docs/agents-runtime/STOQUIFY_AGENT_RUNTIME_SKILLS_016_017_RERUN_REPORT_2026-07-25.md` and matching PDF.

Selected skill: `016-aqstoqflow-ai-copilot-guardrails`

Decision: Passed for the implemented deterministic Phase 2A boundary. The agent remains tenant-scoped, evidence-backed, read-only, provider-free, auditable, reversible, and unable to execute business writes.

Selected skill: `017-aqstoqflow-enterprise-release-gate`

Decision: `NO-GO` for internal activation and `NO-GO` for Phase 3. Repository implementation is technically credible, but the gate cannot authorize promotion without real product and security approvals, six accepted owner assignments, an immutable clean-commit CI certificate, deployed reconciliation, healthy production alert transport, credential-rotation evidence, and the outstanding statutory source/expert evidence required by the global release chain.

Files changed in the final hardening slice

- Dependency-ordered Playwright project and reversible zero-persistence degradation fixture
- Second-tenant seed, auth state, release-isolation scenario, and core-dashboard entitlement contract
- Browser-report completeness and sanitization contract with focused tests
- Phase 2A static gate enforcement for the expanded browser certificate
- Agent action boundaries and release-command boundary
- Agent runner, governance, reconciliation, release-control, freshness, and Command Agent services
- Durable reconciler invocation service, worker, additive ledger migration, route readiness, credential rotation path, and PostgreSQL smoke
- Reconciler readiness evidence collector, sanitized window contract, hash-bound scheduler patch, runbook, and focused tests
- Machine-readable credential-rotation register, Markdown/PDF rendering, fail-closed validator, package commands, and focused tests
- Unified operational release evidence register, validator, package/release wiring, Phase 2A ratchet, and focused tests
- Workflow Assurance alert delivery and cash-shortage persistence boundaries
- Raw error-boundary policy gate and regression tests

- Command Agent action non-leakage regression
- This assurance report and its PDF rendering

Gates passed

Tenant isolation, RBAC/module enforcement, read-only authority, release authorization ordering, idempotency, safe error mapping, audit evidence, alert retry/dead-letter recovery, durable scheduler invocation controls, sanitized hash-bound readiness capture, value-free operational evidence validation, PostgreSQL persistence, TypeScript, build, focused and full tests, CI configuration, and local migration safety.

Gates blocked

Real approvals and owner acceptance; deployed five-minute scheduler and managed authentication; production alert transport and acknowledgement; clean immutable CI/deployment identity; credential rotation; production-only secrets/database target; statutory source artifact hash and expert approval.

Verification result and next numbered skill

The implemented Phase 2A slice is locally verified but not promotable. Remain on `017-aqstoqflow-enterprise-release-gate` until every external gate is evidenced. The next operation is a controlled activation ceremony for the narrow Phase 2A pilot, not Phase 3. Phase 3 may be reconsidered only after the pilot itself meets its exit metrics.

14. Final Position

Stoquify's local Agent Runtime Phase 2 assurance is now credible and substantially more professional. The system proves that the Command Agent can be useful while remaining evidence-backed, tenant-scoped, read-only, observable, reversible, and unable to exercise business authority.

That is the correct foundation for Stoquify's differentiation: trusted daily operational intelligence across accounting, cash, stock, payroll, people, close, and compliance without turning an AI layer into a second system of record.

The remaining work is not optional paperwork. It is the real-world conversion of local controls into accountable operations. Until that evidence exists, the correct decision remains:

NO-GO - READY FOR CONTROLLED REMEDIATION VERIFICATION